Flaw Remediation (SI-2)

Agencies shall identify, report, prioritize, mitigate, and correct system flaws affecting State information systems, applications, infrastructure, firmware, network devices, cloud services, containers, software libraries, and agency-managed technology services.

Agencies shall test software and firmware updates related to flaw remediation for effectiveness and potential operational side effects before installation, where testing is feasible within the required mitigation timeframe. Testing shall not be used to defer required mitigation for vulnerabilities that are internet-facing, actively exploited, listed in the CISA Known Exploited Vulnerabilities catalog, or otherwise designated by DET/BOS as high risk.

Agencies shall install, deploy, or otherwise implement security-relevant software and firmware updates according to the following tiered prioritization and timeframes.

I. Prioritization and Remediation Expectations

Tier 1: Critical Public-Facing Vulnerabilities, CISA Known Exploited Vulnerabilities (KEV), and Emergency Risk Findings

Tier 1 includes:

- Critical and high vulnerabilities on internet-facing systems;
- vulnerabilities listed in the CISA KEV catalog;
- vulnerabilities under active exploitation;
- vulnerabilities affecting identity, privileged access, security tools, remote access, or broadly reachable services; and
- vulnerabilities designated by DET/BOS as requiring emergency mitigation.

For Tier 1 vulnerabilities, agencies shall implement approved mitigation or compensating controls within **24 hours** of discovery, notification, or DET/BOS direction.

Full remediation shall be completed within **seven calendar days**, unless DET/BOS or CISA establishes a shorter required timeframe.

Full remediation may include patching, clean deployment, secure configuration change, version upgrade, service replacement, system rebuild, removal of the vulnerable component, or retirement of the affected system.

Tier 2: High-Risk Internal, Protected, or High Vulnerabilities

Tier 2 includes:

- Critical vulnerabilities on internal, isolated, or effectively protected systems;
- High vulnerabilities affecting regulated data, sensitive data, or enterprise operations; and
- Vulnerabilities that based on relevant agency or DET/BOS standards, present elevated risk grounded in threat intelligence, system exposure, exploitability, or business impact.

For Tier 2 vulnerabilities, agencies shall implement approved mitigation or compensating controls within **48 hours** of discovery, notification, or DET/BOS direction.

Full remediation shall be completed within **15 calendar days**.

Tier 3: Moderate and Low Vulnerabilities

Tier 3 includes Moderate and Low vulnerabilities that are not internet-facing, not actively exploited, not broadly reachable, not associated with privileged access, and not otherwise designated as high risk by DET/BOS.

Agencies shall complete remediation within **30 calendar days**, or according to a DET/BOS-approved vulnerability management schedule based on risk, exposure, and operational impact.

II. Remediation Preferences and Ongoing Operations

Clean Deployment Preference

To support rapid remediation and reduce configuration drift, agencies shall prioritize clean deployments over manual, in-place patching where technically feasible and as resources and operational priorities permit. Where such capabilities do not currently exist, implementation may require additional configurations, automation, testing, and operational resources which should be evaluated as part of the planning.

Clean deployment includes redeployment of an updated and validated system image, container, infrastructure-as-code template, cloud-native service configuration, or managed platform instance.

- For cloud-native, containerized, virtualized, or image-managed systems, clean deployment is the preferred remediation method unless the system owner documents why in-place patching is required.
- For internally developed applications, post-deployment patching should not be the default operating model. Secure build, automated testing, software composition analysis, code scanning, dependency updates, clean deployment, and continuous monitoring should be incorporated into DevSecOps pipelines wherever feasible.

Configuration Management

Agencies shall incorporate flaw remediation into configuration management, change management, asset inventory, vulnerability management, incident response, and system authorization processes.

Asset and vulnerability data shall feed the enterprise vulnerability and asset platform.

Emergency mitigation may proceed outside the normal change window when required to reduce material cyber risk, provided the action is documented after implementation.

III. Failure to Meet Remediation Expectations

Systems Unable to Meet Required Timeframes

Systems that cannot meet required mitigation or remediation timeframes outlined above based on tier level due to fragility, end-of-support status, operational dependency, vendor constraint, business impact, or technical limitation must receive an approved disposition consistent with the following:

Dispositions must be time-bound, documented, reviewed before expiration, and tied to a permanent remediation, modernization, replacement, migration, retirement, or decommissioning path.

The authorized agency decision-maker* shall approve one of the following dispositions:

1. **Patch or remediate on an approved extended timeline**
   The plan must include a defined completion date, interim milestones, and an accountable owner.

2. **Apply DET/BOS preapproved compensating controls and accept residual risk**
   This option requires both implementation of compensating controls from the DET/BOS preapproved list and documented acceptance of the remaining risk.

The risk acceptance must include business justification, scope, expiration date, residual risk statement, compensating controls applied, and accountable executive approval.

3. **Decommission or replace the system**
   This applies when the system is no longer needed, unsupported, duplicative, or cannot be secured at reasonable cost.

4. **Take the system offline temporarily**
   This applies when the system cannot be patched, protected, isolated, or otherwise secured within the required timeframe. This can be implemented for the entire system or in part for the specific impacted components.

If a system is too fragile to patch and no approved compensating control is viable, taking the system offline is an authorized mitigation option.

Unsupported or Unpatchable Systems

Executive branch agencies remain responsible for systems, applications, software, firmware, and components that no longer receive security patches or cannot be remediated within required timeframes.

Unsupported or unpatchable systems shall not remain online without an approved disposition, documented residual risk acceptance, and applicable compensating controls. Risk acceptance must be time-bound and reviewed before expiration.

*Note: If a business risk is significant enough that it exceeds the authority, risk tolerance or decision-making scope of the normal management chain, it will be important that those are

communicated up to the Agency Secretary (or Secretary's Office) for further discussion with DOA and the Governor's Office.

ISSUANCE DATE	VERSION	CHANGES
6-12-26	1.0 [DRAFT]	Original Draft Issued
7-6-26	1.1 [DRAFT]	Agency Comments Draft Issued
7-13-26	1.2	Update Issued